

Disaster Recovery & Business Continuity Planning

DR vs BCP

BCP (Business Continuity): keep the BUSINESS operating (people, alt sites, manual workarounds)

DR (Disaster Recovery): recover IT specifically (systems, data, backup restores)

Recovery site tiers

Tier	Standby	RT0	Cost
Hot	Ready to cutover live	<1h	\$\$\$
Warm	Bootable from replica, not running	4-24h	\$\$
Cold	Facility, no capacity = manual	>24h	\$

Plan structure (the doc)

1. Scope & ownership (who's on call, who declares disaster)
2. BIA recap (RPO/RT0 per system)
3. Response: activation procedure + severity triggers
4. Recovery: per-system recovery steps + tooling + restoration order
5. Communication: escalation tree, external comms (regulators/PR)
6. Stand-down & lessons learned

Testing: the plan is a hypothesis until tested

Tabletop: walk the phone-tree + decisions (cheap, monthly)

Simulation: partial failover with checks (quarterly)

Full failover: cut real traffic to DR (annually, carefully)

Restore test: restore from backup & validate data (the RPO proof!)
Each test → improvement list with owner + dates.

Backup strategy: the DR spine

3-2-1: 3 copies, 2 media, 1 offsite
immutable (ransomware-proof): object-lock / air-gapped
versioned, tested restores monthly minimum

Pitfalls

Plans dated "2021" with no owner – audit finds it, incident kills you
Untested RTO – the classic lie
No communication plan – the second disaster

A BCP/DR that hasn't been tested is a prayer. The tabletop is the cheapest insurance your org will ever 'buy'.

← Business Impact Analysis (BI...

Cyber Insurance & Third-Party ...